

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20 TOTAL MARKS: 20 Annexure A
MOCK INTERVIEW

Code of Conduct:

*I **T Sanhith(192311228)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Annexure A

MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

- **SSL Weaknesses:** Secure Sockets Layer (SSL) versions (specifically SSL 2.0 and 3.0) suffer from severe cryptographic flaws, including weak pseudo-random number generation, vulnerability to padding oracle attacks (e.g., POODLE), and the use of broken cryptographic primitives like MD5 and RC4.
- **TLS Enhancements:** Transport Layer Security (TLS) replaces these broken components with robust cryptographic algorithms (like AES and ChaCha20), strong message authentication codes (HMAC-SHA), and support for Perfect Forward Secrecy (PFS), ensuring that past sessions remain secure even if long-term private keys are compromised.
-

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

- **Step-by-Step Establishment:**
- **ClientHello / ServerHello:** The client and server exchange random numbers and agree on a cipher suite.
 1. **Authentication:** The server sends its digital certificate, which the client validates using trusted Certificate Authorities.
 2. **Key Exchange:** Using asymmetric cryptography (or Diffie-Hellman), the parties securely exchange or negotiate a pre-master secret.
 3. **Session Key Derivation:** Both the client and server independently feed the client random, server random, and the pre-master secret into a pseudorandom function to generate identical symmetric **session keys** for encrypted data transfer.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

- **Comparison:** SSL relies heavily on older, deprecated cryptographic suites and custom mac algorithms. TLS standardizes and modernizes these algorithms
- **Key Improvements:** TLS introduces

1. **Alert Protocol handling** for better error reporting.
2. **Pseudo-Random Functions (PRF)** that split data using two different hash algorithms for heightened security.
3. **Cipher Suite flexibility**, allowing seamless integration of modern authenticated encryption with associated data (AEAD) modes like GCM.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

- **The Risk:** If an application disables or improperly implements certificate validation (e.g., ignoring expired dates, untrusted root CAs, or mismatched domain names), it cannot verify the identity of the server.
- **What Goes Wrong:** An attacker can execute a **Man-in-the-Middle (MitM)** attack. The attacker sits between the client and the real server, presenting a fake certificate. Because the client fails to validate it, the client establishes an "encrypted" session directly with the attacker, exposing sensitive data, passwords, and financial information.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

- **Role:** A digital certificate acts as a digital passport issued by a trusted third party known as a Certificate Authority (CA). It binds a public key to a specific domain name and organization.
- **Ensuring Authentication:** When a server presents its certificate during a TLS handshake, the client verifies the CA's digital signature on that certificate. Because only the legitimate server possesses the corresponding private key, successful decryption and verification prove the server's identity beyond doubt.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

- **SET Protection Mechanism:** Secure Electronic Transaction (SET) uses **dual signatures** to split transaction details.
- **How it works:** It links the payment instruction (credit card details meant only for the bank) with the order information (items bought meant only for the merchant) cryptographically. This ensures the merchant never sees the customer's credit card number, preventing merchant-side database card thefts.

7. Evaluate the limitations of the SET protocol in current online payment systems.

- **Limitations:**

1. **High Complexity:** Requires specialized client-side software (digital wallets) and certificates for every consumer.
2. **Administrative Overhead:** Managing and distributing public key infrastructures to millions of individual shoppers is practically impossible.
3. **Computational Cost:** Heavy asymmetric cryptography per transaction causes severe performance bottlenecks, making it unusable for high-throughput modern e-commerce.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

- **Comparison:** SET focuses on fine-grained separation of data using dual signatures and client certificates. TLS focuses on securing the entire point-to-point communication channel between browser and server.
- **Justification: TLS is vastly more practical today.** It requires zero client-side installation, works natively in every web browser, scales easily to millions of transactions per minute, and achieves compliance through backend tokenization rather than complex client-side protocol layers.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

- **Differentiating Factors:**

Virus: Requires a host file to attach to and demands **user interaction** (like opening an attachment) to execute.

Worm: Self-replicating and propagates autonomously across network connections **without user interaction**.

Trojan: Disguises itself as legitimate or useful software (deception) to trick a user into running it, typically opening a hidden backdoor.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

- **Mitigation Steps:**

Isolation: Immediately disconnect affected network segments or isolate infected

endpoints using automated EDR network containment.

1. **Micro-Segmentation:** Apply VLAN and firewall rules to block the specific network ports (e.g., SMB/RDP) the worm uses to jump between machines.
2. **Patching:** Rapidly deploy emergency security patches to close the specific vulnerability exploited by the worm.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

- **Impact Example:** Consider a user downloading a cracked video game containing a Remote Access Trojan (RAT).
- **Confidentiality Breach:** The Trojan secretly records keystrokes, steals saved browser passwords, and exfiltrates corporate documents to an external command-and-control server.
- **Integrity Breach:** It modifies core system files, installs unauthorized background processes, and alters security configurations to ensure persistence, completely compromising the trustworthiness of the system.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

- **Comparison Matrix:**
 - **Virus:** *Propagation:* Attaches to host programs/files; requires human action. *Impact:* Corrupts/deletes files, disrupts system performance.
 - **Worm:** *Propagation:* Network-based, autonomous self-replication. *Impact:* Consumes massive bandwidth, exhausts system resources, crashes networks.
 - **Trojan:** *Propagation:* Relies on social engineering and user deception. *Impact:* Creates backdoors, steals data, compromises system confidentiality and integrity.

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

- **Working:** A packet-filtering firewall inspects network packets at the network layer (Layer 3) and transport layer (Layer 4). It checks static parameters like source IP, destination IP, port numbers, and protocols against an explicit rule base to allow or drop traffic.
- **Limitations:** It is **stateless** (does not remember connection context), making it blind to session states. It cannot inspect application payloads (Layer 7), meaning it cannot stop malicious commands embedded inside authorized port traffic (e.g., malicious HTTP traffic over Port 80).

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

- **Scenario Application:** To allow legitimate web traffic (HTTP/HTTPS) to a web server while blocking all other inbound access, an administrator configures ordered rules:
 1. *Rule 1:* Allow Source: ANY, Destination: WebServer_IP, Port: 80/443, Protocol: TCP → **ACTION: ALLOW**
 2. *Rule 2:* Allow Source: Internal_Admin_IP, Destination: Management_Server, Port: 22, Protocol: TCP → **ACTION: ALLOW**
 3. *Rule 3 (Implicit Deny):* Source: ANY, Destination: ANY → **ACTION: DROP**

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

- **Effectiveness:** Stateful inspection firewalls are vastly superior because they maintain a state table tracking active connection states (e.g., knowing whether a packet is part of an established TCP handshake).
- **Advantage:** While stateless firewalls evaluate every packet in isolation (allowing crafty attackers to spoof return traffic headers), stateful firewalls automatically drop unsolicited inbound packets that do not correspond to an outbound connection initiated from the inside.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

- **Comparison:** Packet-filtering (fast, basic headers), Stateful (context-aware), and Next-Generation Firewalls (NGFWs - deep application inspection, user identity mapping, and integrated threat intelligence).
- **Recommendation:** An NGFW is the most suitable for an enterprise network because modern threats operate at Layer 7, and enterprises require unified capabilities like malware scanning, intrusion prevention, and deep application control within a single perimeter device.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

- **Signature-Based Detection:** Compares incoming packet patterns or byte strings against a database of known malware signatures or attack patterns. It is highly accurate for known threats but blind to zero-days.
- **Anomaly-Based Detection:** Establishes a baseline profile of normal network behavior (using statistical models or machine learning). It flags any significant deviation from this baseline as suspicious, allowing it to catch novel, unknown (zero-day) attacks.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

- **Prevention Mechanism:** An inline IPS monitors real-time traffic volume and packet structure. When it detects a volumetric flood or an abnormal surge of SYN packets indicative of a DDoS attack, it automatically triggers threshold-based rate-limiting, drops malformed packets instantly, and dynamically applies blacklisting rules to block attacking source IPs before they overwhelm internal servers.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

- **IDS (Intrusion Detection System):** Operates out-of-band (passive). It analyzes traffic copies and issues alerts or logs when an attack is found, but takes **no direct action** to stop the traffic.
- **IPS (Intrusion Prevention System):** Operates inline (active). It sits directly in the traffic path and immediately takes preventive actions (such as dropping packets, resetting connections, or blocking IPs) the millisecond a threat is identified.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

- **Proposed Improvements:**
 1. **Behavioral Baseline Tuning:** Continuously update machine learning models to adapt to legitimate network changes and seasonal traffic shifts.
 2. **Whitelisting:** Exclude known-good internal activities, such as scheduled vulnerability scanners and backup routines, from triggering alerts.
 3. **Signature Refinement:** Disable overly broad signatures and tailor rules specifically to match the operating systems and software versions actually present in the infrastructure.